

Clase 302 — Preparación OSCP: mentalidad Try Harder

Parte: **16 — Capstones y preparación de certificaciones** · Fuente: *Offensive Security PEN-200 · Georgia Weidman, Penetration Testing* 🕒 Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Que el alumno interiorice la **metodología y la mentalidad** que exige el OSCP: enumeración exhaustiva, toma de notas disciplinada, gestión del tiempo bajo presión y persistencia ("Try Harder") sin caer en la frustración improductiva. No se trata de memorizar exploits, sino de tener un **proceso repetible** que funcione contra máquinas desconocidas.

⚠️ **Ética y legalidad:** todo lo aquí descrito se practica **únicamente** en laboratorios propios, plataformas autorizadas (HTB, PG Play, TryHackMe) o el laboratorio oficial de Offensive Security. Escanear o explotar sistemas de terceros sin permiso escrito es delito.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Aplicar** una metodología de enumeración → explotación → escalada → documentación repetible.
2. **Gestionar el tiempo** de un examen de 24 h con un plan de puntos y rotación de objetivos.
3. **Documentar** cada paso con capturas y comandos para reconstruir el informe.
4. **Reconocer** el "rabbit hole" y saber cuándo pivotar a otra máquina.
5. **Preparar** una plataforma de práctica progresiva hasta el nivel de examen.

📖 Temas

#	Tema	Por qué importa
1	Filosofía "Try Harder"	Persistencia estructurada, no fuerza bruta ciega
2	Metodología de enumeración	El 80% del éxito está en enumerar bien
3	Gestión del tiempo y puntos	24 h + informe: hay que optimizar
4	Toma de notas (CherryTree/Obsidian)	Sin notas no hay informe ni repetición
5	Escalada de privilegios	Windows y Linux: patrones recurrentes
6	Reglas del examen	Metasploit limitado, sin herramientas automáticas prohibidas
7	Plan de práctica progresiva	De fácil a difícil hasta simular el examen

Definiciones y características

- **Try Harder:** lema de OffSec que promueve la resolución autónoma. *Característica:* persistir con **método**, no repetir lo mismo esperando otro resultado.
- **Rabbit hole:** pista falsa que consume horas sin resultado. *Característica:* reconocerlo pronto y pivotar.
- **Low-hanging fruit:** vulnerabilidad fácil que da puntos rápidos. *Característica:* se caza con buena enumeración inicial.
- **Foothold:** primer acceso a la máquina (usuario sin privilegios). *Característica:* paso previo a la escalada.
- **Privilege escalation:** pasar de usuario a root/SYSTEM. *Característica:* se apoya en enumeración local (kernel, SUID, servicios, tokens).
- **Proof.txt / local.txt:** banderas que prueban el compromiso. *Característica:* son la evidencia puntuable del examen.

Herramientas y preparación

- **Kali Linux** actualizado (tu VM de la Clase 010 / equivalente).
- Enumeración: `nmap`, `autorecon`, `ffuf` / `gobuster`, `enum4linux-ng`, `nikto`.
- Escalada: `linpeas.sh`, `winPEAS.exe`, `pspy`, `GTF0Bins`, `LOLBAS`.
- Notas: **CherryTree** u **Obsidian** con plantilla por máquina (puertos, servicios, creds, PoC, escalada).
- Plataformas de práctica autorizadas: HTB, Proving Grounds Play/Practice, TryHackMe.
- Plantilla de informe (la reutilizarás en la Clase 303).

Laboratorio guiado

Practica solo en máquinas de plataformas autorizadas o propias.

1. **Prepara la plantilla de notas.** Crea en Obsidian un nodo por máquina con secciones: Recon, Servicios, Vulnerabilidades, Foothold, PrivEsc, Loot, Screenshots.
2. **Enumeración de puertos.** Lanza un escaneo completo:

```
bash nmap -p- --min-rate 2000 -oN nmap-full.txt 10.10.10.10 nmap -p 22,80,445 -sVC -oN nmap-serv.txt 10.10.10.10
```

3. **Enumeración de servicios.** Para HTTP: `ffuf -u http://10.10.10.10/FUZZ -w /usr/share/wordlists/dirb/common.txt`. Para SMB: `enum4linux-ng 10.10.10.10`.
4. **Identifica el vector.** Cruza versiones con `searchsploit` y valida manualmente antes de lanzar nada.
5. **Consigue foothold.** Obtén una shell de usuario; documenta el comando exacto y captura `local.txt`.
6. **Escala privilegios.** Corre `linpeas.sh` / `winPEAS.exe`, analiza el output y busca el patrón (SUID, cron, token, servicio mal configurado). Captura `proof.txt`.
7. **Cronometra.** Anota cuánto tardaste en cada fase; identifica dónde caíste en un rabbit hole.
8. **Simula el examen.** Reserva un bloque de 8 h y ataca 3 máquinas seguidas rotando cuando te atasques 45 min.

Ejercicios

1. Redacta tu **checklist de enumeración** de una página (puertos → servicios → web → SMB → escalada).
2. Resuelve tres máquinas fáciles documentándolas con la plantilla completa.
3. Define tu **regla de pivote**: ¿cuántos minutos sin avance antes de cambiar de máquina?
4. Practica una escalada Linux por SUID y una Windows por servicio inseguro.
5. Cronometra una máquina de dificultad media y calcula tu ritmo de puntos/hora.
6. Escribe un mini-writeup de una máquina como si fuera para el informe.

Reto verificable

Resuelve **cinco máquinas** de una plataforma autorizada (mezcla Linux/Windows, dificultad creciente) y entrega un cuaderno de notas con enumeración, foothold, escalada y capturas de banderas para cada una.

Criterio de aceptación: las 5 máquinas tienen `local.txt` y `proof.txt` capturados, cada nota permite reconstruir el ataque sin volver a la máquina, y al menos una escalada es de Windows y otra de Linux.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Llevo 3 h en la misma máquina"	Rabbit hole; aplica tu regla de pivote y vuelve luego.
"No encuentro vector"	Enumeración incompleta; re-escanea todos los puertos y servicios.
"Perdí los comandos que usé"	Sin notas; nunca ejecutes sin registrar el paso.
"Metasploit me bloqueó puntos"	Uso más allá de lo permitido; conoce las reglas del examen.
"No me da el tiempo"	Falta de gestión; asigna presupuesto de horas por máquina.

Preguntas frecuentes

 **¿Cuántas máquinas necesito resolver antes del examen?** No hay número mágico, pero listas como TJ Null (HTB/PG) sugieren 40–60 máquinas variadas para consolidar patrones.

 **¿Puedo usar Metasploit en el examen?** Solo de forma limitada (una máquina) y con restricciones. Domina las técnicas manuales.

 **¿Cómo evito bloquearme mentalmente?** Descansa, enumera de nuevo desde cero y verbaliza qué has probado. El bloqueo suele venir de asumir algo no verificado.

 **¿Qué app de notas conviene?** CherryTree u Obsidian; lo importante es la disciplina, no la herramienta.

Referencias

- Offensive Security PEN-200: <https://www.offsec.com/courses/pen-200/>
- OSCP Exam Guide: <https://help.offsec.com/hc/en-us/articles/360040165632>
- Georgia Weidman, *Penetration Testing* (No Starch Press).
- HackTheBox: <https://www.hackthebox.com/>

- GTFOBins: <https://gtfobins.github.io/> · LOLBAS: <https://lolbas-project.github.io/>

Siguiente clase

Clase 303 - Capstone: laboratorio completo de pentest